

Threats to Privacy and Privacy Protection

Modes of Learning

For this module, the following modes of learning will be used:

- Interactive Module
- Textbook Readings
- Online Quizzes

Introduction

This module provides an overview of issues surrounding privacy, privacy law and threats to privacy, along with an analysis on general principles for privacy protection.

A cybersecurity incident can lead to a data breach that compromises the personal information of customers, employees or other people. The harm caused by such breaches includes not only financial loss, but also mental anguish or embarrassment; as a consequence, organizations risk negative reputational costs, loss of trust in the business and potentially costly lawsuits.

Organizations are often tempted to resolve cybersecurity incidents without reporting them to regulators or notifying affected people. However, this approach would result in greater harm if the breach became known to the public; the organization would be perceived as irresponsible and not committed to following privacy best practices. It is therefore critical to comply with privacy laws concerning breach notification and reporting obligations, and also to consider breach notification as a business best practice that demonstrates accountability.

As you begin this module, please refer to the timeline and make note of any assessments or important dates. If you have any questions, ask your instructor.

Learning Outcomes

Upon completion of this module, you will be able to:

1. Analyze issues surrounding privacy, privacy law and threats to privacy.
2. Discuss general principles for privacy protection.

Key Terms & Concepts

Listed below are some important key terms and concepts within this module.

- PIPEDA
- Real Risk
- Ontario PHIPA
- Significant Harm
- Mandatory Breach Notification

Identify and Understanding the Breach

As soon as a data breach occurs where personal information might be compromised, it is important to determine and record the following ten facts, as accurately and as quickly as possible:

1. When did the breach occur?
2. When the breach was discovered?
3. Who identified the breach (internally or externally)? What is their relationship to the organization?
4. A description of the incident.
5. The cause (or suspected cause) of the breach.
6. The number of people affected.
7. Where are the affected people are located?
8. Personal information involved (be specific, to determine the sensitivity of the information).
9. People and organizations involved in investigating/addressing the breach internally and externally.
10. Steps being taken or to be taken to mitigate harm.

The sector in which an organization operates—private, public or health—along with the answer to number 7 above determines the statutory breach reporting and notification obligations of the organization that experienced the breach.

Private Sector (A) Alberta PIPA

Alberta is currently the only Canadian province that requires data breach reporting. This requirement has been in effect since May 2010, under Section 34.1(1) of Alberta's Personal Information Protection Act (PIPA).

When any organization determines that there is a real risk of significant harm to an Alberta resident, regulations dictate that they must report the privacy breach to the Office of the Information and Privacy Commissioner of Alberta, in writing; Section 19 of the PIPA sets out a list of the information to be reported.

When an organization suffers a breach that must be reported under PIPA, the Alberta Commissioner has the authority under Section 37.1 to require the organization to notify people affected by the breach.

Under Section 37.1(7) of PIPA, an organization is neither prohibited nor restricted from notifying people of a breach on its own initiative. The Alberta Commissioner encourages organizations who notify the people voluntarily with the information prescribed under the regulations to avoid the potential of having to re-notify affected individuals, should the Alberta Commissioner require notification under Section 37.1.

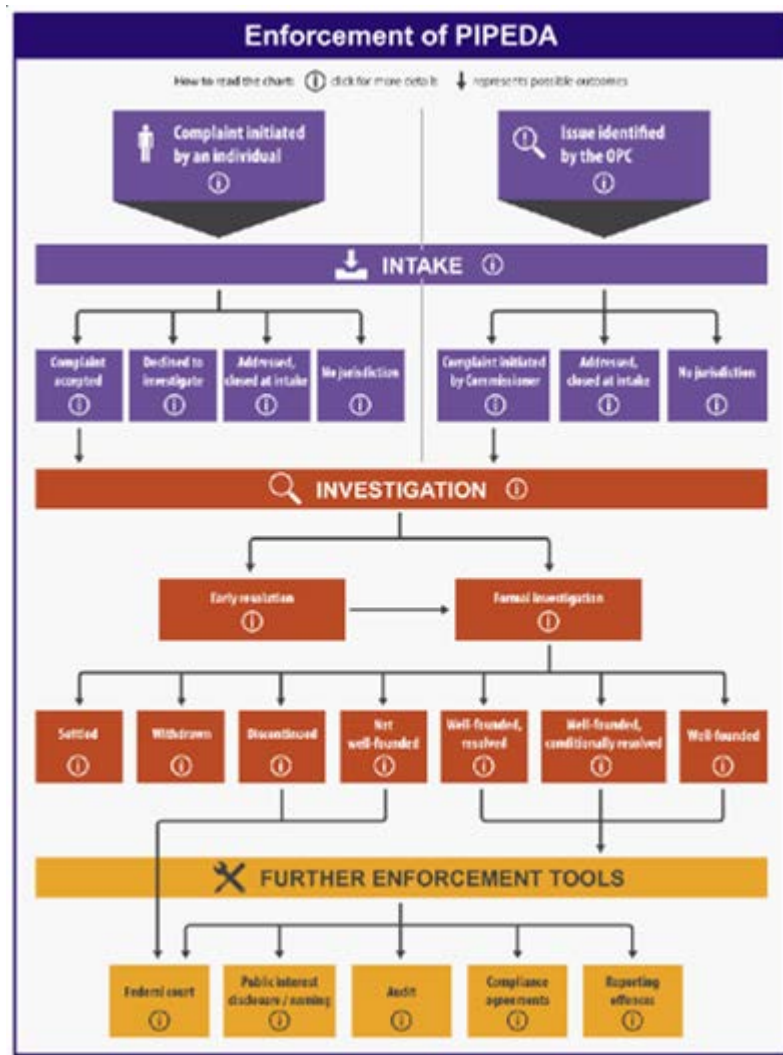
PIPA does not provide any criteria to assist organizations in determining what is a "real risk of significant harm." However, the decisions by the Alberta Commissioner indicate that "harm" is broadly interpreted to include identity theft, fraud/financial loss, mental anguish, embarrassment or reputational harm.

Private Sector (B) Federal PIPEDA

At a federal level, the Personal Information Protection and Electronic Documents Act (PIPEDA) applies to the protection of personal information collected by federal works, undertakings and businesses. With

respect to businesses, it applies to banks, telecommunications companies, airlines, railways and other interprovincial undertakings. PIPEDA also applies to provincially regulated businesses in the provinces that do not have substantially similar private sector privacy legislation.

On June 18, 2015, the Digital Privacy Act was enacted and amended PIPEDA in several key ways. These amendments introduced new breach notification and reporting provisions that have not yet been proclaimed into force.



The trigger for reporting and notification of a “breach of security safeguards involving personal information” is a “real risk of significant harm to an individual.” Unlike the Alberta approach, PIPEDA provides guidance on this test, broadly defining “significant harm” as including the following:

- Bodily harm
- Humiliation
- Damage to reputation or relationships
- Loss of employment, business or professional opportunities
- Financial loss
- Identity theft

- Negative effects on credit record
- Damage to or loss of property

Criteria for determining whether there is a “real risk” include the sensitivity of the personal information involved in the breach, and the probability that the personal information involved in the breach will be misused.

Once a breach is discovered and confirmed, an organization must report it to the Office of the Privacy Commissioner of Canada (OPCC) in the prescribed form “as soon as feasible,” and the people affected by the breach must also be notified.

The notice must contain enough information for people to understand the significance of the breach and to take steps, if possible, to reduce the risk of harm. Furthermore, the notice must be conspicuous and given directly to the individual, except in certain circumstances where indirect notice (e.g. posting to a website) is permitted under Section 10.3 of PIPEDA.

Once the Breach of Security Safeguards Regulations are in force under Section 10.2 of PIPEDA, organizations will be required to notify any third parties who might be able to reduce risk or mitigate harm caused by the breach.

There will also be record-keeping obligations under Section 10.3 of PIPEDA. These new provisions will impose a fine of up to \$100,000 per violation when an organization knowingly violates the breach notification or reporting requirements.

Mandatory breach notification will present new costs, risks and challenges for organizations, large and small. For instance, the risk of litigation and class actions in the wake of a data breach might be increased following a notification. The amendments might also increase the growing interest in cyber-liability insurance, which often includes liability, defense and other costs associated with responding to data breaches.

Regulators and the courts generally recognize that even the most security-conscious organizations could suffer a data breach—threats and vulnerabilities can quickly shift, and human error is always a risk. An effective and efficient response to a data breach makes all the difference in how the public perceives the breach and the organization.

Consider the example of when Peoples Trust Company (PTC), a federally regulated financial institution based in Vancouver, B.C., suffered a breach. Hackers accessed customer information from a database that held information entered by customers applying for financial products via an online application portal. The incident compromised 12,000 customers’ sensitive personal records. Upon becoming aware of the breach, PTC immediately notified the OPCC, who also began receiving complaints from affected Canadians.

Due to a third party’s redesign of the PTC website and application portal, customer data was stored unnecessarily, duplicated on a vulnerable server in an unencrypted format. The Federal Commissioner’s investigation found that PTC did not implement adequate technological and organizational safeguards on its online application portal. However, the investigation also found that PTC implemented timely and comprehensive measures, including improving safeguards, to contain the breach, reduce the risk to those

affected and reduce the possibility of future breaches. PTC's effective and efficient breach response plan reduced the reputational costs stemming from the breach.

Voluntary Breach Notification and Reporting

In 2007, the OPCC published voluntary guidelines, titled "Key Steps for Organizations in Responding to Privacy Breaches." The guidelines outline four key steps to take when responding to a breach:

1. Breach Containment and preliminary assessment
2. Evaluating the risks associated with the breach
3. Notification
4. Prevention of future breaches

Under the voluntary breach response guidelines, organizations are encouraged to consider the following factors in assessing risk:

- a. The personal information involved, including its sensitivity, whether it was anonymized or encrypted, and whether it can be used to inflict harm.
- b. The cause and extent of the breach.
- c. The people affected by the breach, including how many and whether they were customers, employees or clients of the organization.
- d. Foreseeable harm from the breach.

Health Sector

Ontario PHIPA

Provincial health privacy laws in Ontario, Nova Scotia, New Brunswick, and Newfoundland and Labrador contain breach notification and/or reporting requirements for the health sector. There is no mandatory breach reporting or notification obligations in Alberta, Saskatchewan and Manitoba. However, these provinces do have health privacy laws.

Under Ontario's Personal Health Information Protection Act (PHIPA), if personal health information is stolen, lost, used or disclosed without authority, applicable health information custodians must notify affected people at the first reasonable opportunity.

PHIPA was amended by the Health Information Protection Act on May 18, 2016, but the amendments are not yet in effect.

These amendments will attempt to address the growing problem of medical snooping, entailing the following:

- Individual notification will be extended to any unauthorized access or use by an employee.
- Health information custodians will be obligated to report breaches to the Ontario Information and Privacy Commissioner.
- When a health information custodian terminates, suspends or disciplines an employed health professional due to unauthorized collection, use, disclosure, retention or disposal of personal health information, the college of the regulated health professional must be notified in writing within 30 days.

Nova Scotia PHIA

The Nova Scotia Personal Health Information Act (PHIA) came into effect in June 2013. Under Section 69 of PHIA, a health information custodian must notify an individual at the first reasonable opportunity if the custodian believes that an individual's personal health information was stolen, lost or subject to unauthorized access, use, disclosure, copying or modification, and that there is a potential of harm or embarrassment to the individual.

If the custodian determines that a breach of personal health information was unlikely, or there is no potential for harm or embarrassment, the custodian may choose not to notify the individual but is then required to notify the Privacy Review Officer as soon as possible.

New Brunswick PHIPAA and Newfoundland and Labrador PHIA

The New Brunswick Personal Health Information Privacy and Access Act (PHIPAA) and the Newfoundland Privacy Health Information Act (PHIA) both require that a custodian notify affected individuals and the Commissioner at the first reasonable opportunity if personal health information is stolen, lost, disposed of, disclosed to or accessed by an unauthorized person, and if the custodian believes that there could be an adverse impact on the provision of health care to the individual, or the individual's mental, physical, economic or social wellbeing.

The Newfoundland PHIA has an additional requirement: the custodian must also inform the provincial commissioner of "material breaches."

The Newfoundland PHIA has an additional requirement: the custodian must also inform the provincial commissioner of "material breaches". Section 5 of the Newfoundland PHIA sets out the factors that determine what constitutes a material breach. **These factors include:**

These factors include:

- The sensitivity of the personal health information.
- The number of people whose personal health information was involved.
- Whether the custodian believes that the information will be misused.
- Whether the cause of the breach or pattern of breaches indicates a systemic problem.

Public Sector

In the public sector, no provincial freedom of information and protection of privacy laws require organizations to report data breaches or notify affected people. However, various provinces offer guidance on involving the provincial information and privacy commissioner's office when assessing the risk associated with a breach.

At the federal level, the Treasury Board's "Directive on Privacy Practices" was amended in May 2014, to require reporting of all material privacy breaches experienced by federal government institutions to both the Office of the Privacy Commissioner of Canada and the Treasury Board of Canada Secretariat. A material privacy breach is defined as involving sensitive personal information and one that could be expected to cause serious injury or harm to the individual and/or involved a large number of affected individuals.

The report must include:

- Nature and extent of the breach.
- Steps taken or to be taken to notify individuals, and what remedial actions has been taken.
- Type of personal information and parties involved.
- The anticipated risks of harm.

Module Summary

In this module you have learned:

1. Organizations have mandatory breach notification and reporting obligations, which are based on an assessment of risk to the individuals and organizations affected by the breach.
2. Different governing jurisdictions (provincial, federal) have different statutory requirements and regulators concerning privacy.
3. To minimize the negative impact of a breach, an organization must take responsibility and communicate with stakeholders effectively, openly and sincerely.

Knowledge Check

The following questions provide an opportunity for you to see what you remember and understand so far. Answer the questions to the best of your ability.

1. **It is critical to comply with both the statutory breach notification and the reporting obligation under privacy laws, and to consider the breach notification as a business best practice that demonstrates accountability.**
 - a. True
 - b. False
2. **PIPEDA defines “significant harm” as including:**
 - a. Bodily harm and humiliation
 - b. Damage to reputation or relationships and loss of enjoyment, business or professional opportunities
 - c. Financial loss, identity theft, negative effects on the credit record and damage to or loss of property
 - d. All of the above
3. **The federal PIPEDA applies only to the protection of personal information collected by federal works.**
 - a. True
 - b. False
4. **The factor to consider when determining whether there is a “real risk” include:**
 - a. Sensitivity of the personal information involved in the breach; and
 - b. Probability that the personal information will be misused.
 - a. True
 - b. False
5. **Notice to individuals and the report to the Office of the Privacy Commission of Canada are not required to be given within a specified time.**
 - a. True
 - b. False
6. **PIPEDA does not require organizations to notify any third parties of the breach.**

- a. True
 - b. False
7. The new provisions under the PIPEDA will impose a fine of up to \$100,000 per violation.
- a. True
 - b. False
8. What is the trigger for reporting and the notification of a “breach of security safeguards involving personal information”?

Answers:

- 1. True
- 2. All of the above
- 3. The answer is false because it applies also to undertakings.
- 4. True
- 5. The answer is false because notice must be given “as soon as feasible” after it is determined that a breach has occurred.
- 6. The answer is false because third parties who may be able to reduce risk or mitigate harm must be notified.
- 7. False
- 8. “Real risk of significant harm to an individual.”

You have completed: Threats to Privacy and Privacy Protection

Remember to check the timeline before you proceed to the next module to ensure you have completed any assignments as required. Check with your instructor if you have any questions.